

TAM THUC STRATEGEM

Security Architecture and Threat Model v1.0

1. THREAT MODEL (STRIDE)

- ****Spoofing****: JWT validation + rate limiting.
- ****Tampering****: Input validation + signed calculations.
- ****Repudiation****: Comprehensive audit logging.
- ****Information Disclosure****: Encryption at rest + least privilege.
- ****Denial of Service****: Rate limiting + auto-scaling + WAF.
- ****Elevation of Privilege****: Role-based access control (RBAC).

2. SECURITY CONTROLS

- Data at rest: AES-256 (birth_data encrypted).
- Data in transit: TLS 1.3.
- Secrets: Managed via environment variables / secret manager.
- Dependency scanning: Snyk or Dependabot.
- Regular penetration testing (annual + after major changes).
- OWASP Top 10 mitigation checklist.

3. INCIDENT RESPONSE

- Playbook cho data breach, calculation error, abuse.
- Notification timeline theo regulation (GDPR 72h, VN PDPA).
- Post-incident review process.